Apex Solutions

Service Catalogue, Delivery Blueprint and Pricing Guide

Software, AI, Data Analytics, Cloud and Business Intelligence Solutions

Version 1.1 | October 2026

Contents: 1. Company overview 2. Service catalogue and launch tiers 3. Pricing guide (KES) 4. Software Requirements Blueprint (SRB) 5. Per-service requirements 6. Hosting, Docker and infrastructure costs 7. AI-assisted delivery workflow 8. Compliance and legal (Kenya) 9. Standard terms 10. 90-day launch roadmap 11. Universal pre-launch checklist. Companion standard: Apex Security Baseline and Verification Standard.

All prices are suggested starting ranges in Kenya shillings and exclude VAT, cross-checked against published 2026 Nairobi agency rates and provider pricing as of October 2026. Cloud and domain prices change often, so confirm before quoting a client.

1. Company Overview

Apex Solutions builds software for businesses: websites, web applications, point-of-sale (POS) systems, mobile apps, AI tools and data platforms, then hosts and maintains them. We position as a full technology solutions company rather than a web developer, which leaves room to grow into new sectors without rebranding.

How we deliver

- Every project starts with a written blueprint (the SRB in Section 4). The blueprint matters more than the code: a vague blueprint produces poor software very quickly, a detailed one lets AI generate most of the application correctly.
- AI accelerates design and code generation (GPT for page designs, Claude for implementation). Humans own requirements, security review, testing and sign-off.
- Every application is built to the **Apex Security Baseline** (the companion standard): security controls are specified in the blueprint, tested on staging and proven with an evidence pack before go-live. Security is a condition of delivery, not an extra.
- Clients get a staging link, written acceptance criteria, documentation and a handover. Hosting and maintenance are sold as recurring plans.

What makes Apex different

- Fixed-scope packages with clear prices, not open-ended hourly billing.
- Kenya-ready by default: M-Pesa, SMS, KRA eTIMS awareness, Data Protection Act awareness.
- A reviewed, repeatable process instead of improvised builds.
- Security you can verify: a defined baseline, tested and evidenced on every build. Critical and High findings are never waived.
- Specialist niche in Finance and Governance Intelligence (company filings, director remuneration, board and ESG analysis).

Existing builds that can serve as case studies (get client permission where they were built for someone else): an e-commerce platform for fashion retail (QT Ladies Collection), a platform tracking NSE-listed companies with a filing PDF import pipeline (a Finance Intel proof of concept), and a football data platform on an external API (Match Oracle).

2. Service Catalogue and Launch Tiers

The full catalogue is below. Because one person cannot credibly deliver every category on day one, services are grouped into launch tiers. List everything on the website under Solutions, but sell Tier 1 first.

#	Category	Services included	Tier
1	Software development	Web apps; ERP, CRM, inventory, procurement, HR and payroll; school, SACCO, cooperative, hospital and property management; booking and membership systems; custom business apps; desktop apps; Android, iOS and cross-platform mobile apps	1 (web), 2 (mobile), 3 (hospital, desktop)
2	POS solutions	Retail (supermarket, shop, hardware); hospitality (bar, restaurant, hotel, cafe); specialised (pharmacy, electronics, wholesale, fuel station); add-ons (inventory, suppliers, M-Pesa, cards, analytics, loyalty)	1 (retail, restaurant, pharmacy), 3 (fuel)
3	Website development	Corporate, NGO, school and government sites; e-commerce stores and marketplaces; news portals, blogs, membership and learning platforms	1
4	AI solutions	Chatbots, support bots, knowledge and internal assistants; OCR, PDF and invoice extraction, contract and report analysis; recommendations, AI search, predictive analytics	2
5	Data and analytics	Executive, KPI and operational dashboards; automated, performance and compliance reports; data warehousing, integration and migration	2
6	Finance and governance intelligence	Director remuneration, board composition, ESG reporting, benchmarking, annual report analysis, disclosure quality assessment	3 (niche specialty, build first as a product)
7	Cloud and hosting	Website, app and VPS hosting; server setup, cloud migration, Docker deployment, database hosting; monitoring, backups, maintenance	1 (hosting), 2 (migration, Docker)
8	Cybersecurity	Vulnerability assessments, audits, penetration testing; backups, disaster recovery, access control; monitoring and incident response	3 (needs certifications or a partner)

#	Category	Services included	Tier
9	IT consulting	Digital transformation, technology strategy, software selection; architecture, database design, infrastructure planning	2
10	Integration services	M-Pesa, bank APIs, card gateways; ERP, CRM and accounting integrations; REST and internal APIs	1 (M-Pesa, cards), 2 (ERP and bank APIs)
11	Design services	UI/UX, app, dashboard and mobile design; logos, company profiles, brand guidelines	1
12	Digital services	SEO, optimisation, analytics setup; technical documentation, manuals, knowledge bases	2
13	Support and maintenance	Application support, bug fixes, performance work, upgrades; server and database maintenance, backup management	1
14	Own products	School ERP, student information and learning systems; hotel, bar and restaurant POS; HR, CRM and document management; Finance Intel, governance and ESG platforms	Build from Tier 1 client work

Tier 1: launch now. Websites, e-commerce, web apps and business systems, retail and restaurant POS, M-Pesa and card integrations, hosting and maintenance, UI/UX.

Tier 2: add in 6 to 12 months. Mobile apps (start with PWAs), dashboards, AI tools, cloud migration and Docker, consulting.

Tier 3: specialise or partner. Finance Intel (your differentiator), cybersecurity and penetration testing, hospital systems, fuel-station POS, bank APIs. These carry certification, regulatory or liability burdens.

> **Security is not a Tier 3 item.** Selling cybersecurity services (audits, penetration testing) is Tier 3 and needs certifications or a partner. Securing the applications Apex builds is not optional: the Apex Security Baseline applies to every project from day one.

3. Pricing Guide (KES, one-time build)

Published 2026 Nairobi agency rates put basic sites at roughly KES 10,000 to 100,000, e-commerce at KES 80,000 to 300,000 or more, and custom web applications at KES 150,000 to 500,000 or more. The ranges below sit inside that market. Use the low end for simple scope and a first pilot client, the high end for complex scope, urgent timelines or larger clients. All prices exclude 16 percent VAT.

Service	Price range (KES)	Typical inclusions	Timeline
Landing page / starter site (up to 5 pages)	15,000 - 40,000	Responsive design, contact form, basic SEO	1-2 weeks
Business / corporate website (5-10 pages, CMS)	50,000 - 120,000	Editable content, SEO setup, analytics	2-4 weeks
NGO, school or institutional website	80,000 - 200,000	Multi-section, news, downloads, forms	3-6 weeks
E-commerce store	100,000 - 300,000	Catalogue, cart, M-Pesa and card checkout, order admin	4-8 weeks
Custom web app (portal, booking, dashboard)	150,000 - 500,000	Roles, database, admin panel, API	6-12 weeks
Business system (inventory, HR, payroll, CRM, procurement)	200,000 - 600,000	Modules, reports, roles, audit log	8-14 weeks
School, SACCO or clinic management system	300,000 - 800,000	Multi-module, SMS, M-Pesa, reports	10-16 weeks
Retail POS (shop, minimart)	80,000 - 250,000	Sales, receipts, stock, reports, users	4-8 weeks
Restaurant / bar POS	120,000 - 350,000	Tables, kitchen tickets, split bills, stock	6-10 weeks
Pharmacy or specialised POS	150,000 - 400,000	Batch and expiry tracking, suppliers	6-10 weeks
Progressive web app (PWA)	100,000 - 250,000	Installable, basic offline, push notifications	4-8 weeks
Android / iOS / cross-platform app	250,000 - 800,000	Both stores, push, backend API, store submission	8-16 weeks
AI chatbot or knowledge assistant	60,000 - 200,000	Trained on client documents, web or WhatsApp channel	3-6 weeks

Service	Price range (KES)	Typical inclusions	Timeline
Document extraction (OCR, PDF, invoices)	100,000 - 350,000	Extraction, review screen, export	4-10 weeks
Dashboards and BI reporting	50,000 - 250,000	KPIs, charts, exports, scheduled reports	2-6 weeks
Finance Intel report (per company or sector)	30,000 - 150,000	Remuneration, governance or ESG analysis	1-3 weeks
M-Pesa (Daraja) integration	30,000 - 80,000	STK push, callbacks, reconciliation, go-live support	1-3 weeks
Card or bank gateway integration	30,000 - 100,000	Checkout, webhooks, refunds	1-3 weeks
Cloud setup and Docker deployment	20,000 - 70,000	Server, Docker, SSL, backups, monitoring	2-5 days
Data migration / import	20,000 - 100,000	Cleaning, mapping, validation, reconciliation	1-3 weeks
UI/UX design only	25,000 - 100,000	Wireframes, mockups, design system	1-3 weeks
Discovery and Blueprint (optional, credited against the build price if the client proceeds)	10,000 - 50,000	SRB sections 1-4 and 15-17, risk level, estimate and timeline	1-2 weeks
External penetration test (Level 3 projects, with a certified partner)	Quoted by the partner	Written authorisation, report, retest after fixes	1-3 weeks
IT consulting / system audit	3,000 - 6,000 per hour	Or 25,000 - 60,000 per day	As agreed

How to quote

- Price on value and scope, not on hours or tools. AI is how Apex works, not a pricing factor: prices do not drop because AI writes the code. Clients pay for a working, secure, supported system, and requirements, review, security testing, acceptance testing, hosting and ongoing responsibility cost the same however the code is produced. Time AI saves is margin that funds security testing, support and growth.
- Rule of thumb: (benchmark hours including review, security testing and acceptance testing x your hourly rate) + hosting setup + 15 to 20 percent contingency for changes. Base the hours on what the work would normally take a competent developer, not on your actual AI-assisted time, and track your real hours separately to see your margin. Add a further 10 percentage points on the lines for offline sync, KRA eTIMS and other high-risk integrations.
- Check the effective hourly rate (price divided by hours) against your real costs and a growth margin, and review your internal rate every quarter against the bands above.
- Prices exclude 16 percent VAT. Show VAT-inclusive totals in every proposal, and ask in discovery whether the client's budget includes VAT.
- Offer three packages (Basic, Standard, Premium) for each Tier 1 service so clients can choose rather than negotiate.
- Do not advertise discounts for AI-built or "fast" delivery. If a client has a cheaper quote, compare scope, security evidence, support and ownership terms rather than matching the price.
- Payment schedule: 50 percent on signing the Development Agreement, 30 percent on staging approval, 20 percent on go-live. Work starts only after the agreement is signed and the deposit is received. Never deploy to production before the final payment clears for a new client.
- Always sell a maintenance plan with the build (Section 6.4). Offer POS Care to shops, restaurants and any client that cannot trade when the system is down. Recurring income is what makes a services company stable.
- Level 3 (high-risk) projects need extra review and testing hours. Offer an external penetration test as a separate line item.

4. Software Requirements Blueprint (SRB)

The SRB is the document every project must complete before any code is generated. Sections 1 to 14 are your existing outline; sections 15 to 26 are additions that close the common gaps (scope disputes, integrations, data migration, compliance, release process and sign-off). Section 8 is now completed through the Apex Security Baseline.

#	Section	Must contain	Source
1	Project overview	Name, purpose, target users, business problem, revenue model, success metrics	Your outline
2	User roles	Every role, and for each: what they can see, create, edit, delete	Your outline
3	Portal structure	Public site, authentication, admin, customer, reporting and support portals	Your outline

#	Section	Must contain	Source
4	Page inventory	Every page listed. No code until all pages are identified	Your outline
5	Page specifications	Per page: purpose, components, actions (search, filter, export), permissions	Your outline
6	Database design	Entities, fields, relationships, validation rules, and for each personal-data field its purpose and retention period	Your outline
7	Workflows	Each business process as numbered steps, including approvals and audit logging	Your outline
8	Security checklist	Complete the Apex Security Baseline: the risk level (1 content, 2 application, 3 high risk), applicable controls, exceptions with reasons and the evidence to collect. Covers authentication and password hashing, MFA, authorisation including record ownership, input validation, secrets, headers, data protection, backups, logging and incident response	Your outline, expanded
9	API requirements	Endpoints, inputs, outputs, authentication, rate limits	Your outline
10	Reporting requirements	Dashboards, KPIs, charts, export formats, scheduled reports	Your outline
11	Performance requirements	Measurable targets, such as login under 2 seconds, search under 3 seconds, concurrent users	Your outline
12	Deployment requirements	Dev, test and production environments; VPS, Docker, database, backup strategy	Your outline
13	Testing checklist	Functional, security (Security Baseline sections 6 and 7), performance and user acceptance testing	Your outline
14	Maintenance requirements	Backups, monitoring, logging, updates, incident response	Your outline
15	Scope, exclusions and assumptions	What is included, what is explicitly not, and what we assume (content supplied by client, accounts the client owns, hardware supplied by the client, peak trading periods). Also the security risk level	Added
16	Business rules and calculations	Tax and VAT, discounts, commissions, interest, rounding, stock valuation. Worked examples with expected numbers	Added
17	Integrations and third parties	M-Pesa (Paybill or Till owned by client), SMS, email, WhatsApp, KRA eTIMS, accounting tools. Who supplies credentials, with all access confirmed in week one	Added
18	Notifications and communications	Every email, SMS and push trigger with the exact wording and who receives it	Added
19	Data migration and import	Legacy data sources, cleaning rules, import templates, reconciliation checks	Added
20	Non-functional requirements	Browser and device support, languages (English, Swahili), accessibility, offline needs, expected growth	Added
21	Privacy, compliance and legal	Data Protection Act duties, privacy policy, terms, data retention, data stored outside Kenya only on written instruction, tax-system integration where applicable	Added
22	Design system and branding	Colours, fonts, logo files, approved mockups, component list, tone of voice	Added
23	Environments and release process	Dev, staging, production; version control; deployment steps; rollback plan; the security release gate	Added
24	Backup and disaster recovery	How often data is backed up, where, how long to restore, who tests restores	Added
25	Training, documentation and handover	User manual, admin guide, training sessions, credentials handover, source-code ownership, evidence pack	Added
26	Acceptance, changes and risks	Signed acceptance criteria, change-request process, risks, client responsibilities (including MFA, removing leavers, no shared passwords), milestones and budget	Added

5. Per-Service Requirements

Minimum standards each service must meet before it can be delivered. Treat these as the acceptance criteria that go into SRB section 26.

Service	Must meet
All services (security)	Apex Security Baseline controls for the project's risk level pass with evidence. No Critical or High security finding is open at go-live. The evidence pack is delivered at handover.

Service	Must meet
Websites	Responsive on phone, tablet and desktop; loads in under 3 seconds. SEO basics: titles, descriptions, sitemap, Google Business and Search Console setup. Contact form with spam protection, SSL, analytics. Client can edit content without calling you (CMS or simple admin).
E-commerce	Catalogue, cart, checkout, order emails, stock tracking. M-Pesa and card payments tested with real transactions before launch. Prices, totals and discounts computed on the server; an order is paid only after the provider confirms. Orders, products, customers and discount codes manageable in admin. Delivery fee rules, returns policy page, privacy policy and terms.
Web apps and business systems	Login, roles and permissions, password reset, session timeout. Passwords hashed (argon2id or bcrypt), MFA for admins, access checks on every route and on record ownership. Input validation, error handling, audit trail of who changed what. Production database is PostgreSQL or MySQL (not SQLite) for multi-user systems. Backups, exports to Excel and PDF, admin panel, API documentation.
POS	Fast sales screen, receipts (print and PDF), cash, M-Pesa and card payments. Stock deducts on sale; end-of-day report; refunds and voids logged with user and reason. Works through poor internet (offline queue or quick recovery) and survives power cuts without corrupting data. Tax handling and KRA eTIMS integration confirmed per client; user roles for cashier, manager, owner. Client-supplied hardware and a UPS listed in the blueprint. eTIMS and M-Pesa credentials confirmed in week one, with live transactions accepted before go-live.
Mobile apps	Android and iOS builds tested on real devices; push notifications; offline handling. Backend API with authentication and rate limiting. No secrets in the app; tokens kept in secure device storage. Play Store and App Store accounts in the client's name; privacy policy URL. Update plan: how new versions are released.
AI solutions	Defined scope and a test set of real questions or documents with expected answers. Human review step for anything legal, financial or medical. Confidence scores, source references, logging of AI outputs. Prompt-injection tests; retrieval limited by each user's permissions. Clear cost estimate for ongoing AI usage billed to the client.
Data and analytics	Source systems, refresh frequency and data owner documented. Metrics defined in writing (how each KPI is calculated). Data quality checks and reconciliation against source totals. Role-based access to dashboards; export formats agreed.
Finance Intel	Every data point linked to its source document and page (evidence record). Review and approval step before extracted data enters the database. Version history for restated figures; benchmarking methodology documented. Subscription access control and usage logging.
Integrations	Sandbox testing first, then production go-live with the client's own credentials. Webhook and callback handling with retries and reconciliation. M-Pesa callbacks treated as unconfirmed until verified; each transaction processed once. Secrets stored in environment variables, never in code. Monitoring and alerts for failed transactions.
Cloud and hosting	Documented architecture, Docker configuration and deployment steps. SSL, default-deny firewall, database never publicly reachable, automatic backups, tested restore. Uptime monitoring and error tracking. MFA on every admin account. Client owns domain and accounts; you hold admin access under contract.
Design	Mockups approved by the client before coding starts. Design system: colours, typography, components, empty and error states. Accessible contrast and tap-target sizes; mobile-first layouts.
Consulting and security work	Written scope, findings report and prioritised recommendations. Penetration testing only with written authorisation from the system owner and, until qualified, delivered with a certified partner.

6. Hosting, Docker and Infrastructure Costs

6.1 Which services need hosting

- Always: web apps, cloud POS, e-commerce, APIs, AI services, dashboards, any mobile app backend.
- Cheap options: brochure websites can use shared hosting or a free static host such as Cloudflare Pages.
- Not needed: offline desktop POS and the mobile app binaries themselves (but the client still needs backups, and the Play Store and App Store charge fees).

6.2 Standard Docker stack for Flask applications

Docker Engine and Docker Compose are free. The only real cost is the server. A standard stack for your Flask projects is a reverse proxy (Caddy gets free automatic SSL), Gunicorn running the Flask app, PostgreSQL, and a nightly database dump copied off the server. Replit is fine for prototypes and demos, but move paying clients to a server you control so you can set backups, monitoring and costs predictably.

```
services:
  web:
    build: .
    command: gunicorn -w 3 -b 0.0.0.0:8000 app:app
    env_file: .env
    depends_on: [db]
    restart: unless-stopped
  db:
    image: postgres:16
    volumes: [pgdata:/var/lib/postgresql/data]
    env_file: .env
    restart: unless-stopped
  caddy:
    image: caddy:2
    ports: ["80:80", "443:443"]
    volumes: [./Caddyfile:/etc/caddy/Caddyfile, caddy_data:/data]
    restart: unless-stopped
volumes:
  pgdata: {}
  caddy_data: {}
```

Note: SQLite (used in your current projects) is fine for demos and single-user tools, but multi-user systems such as a POS should run on PostgreSQL in production to avoid write-locking and data-loss risks.

Hardening notes for every deployment

- Keep .env out of Git (.gitignore and .dockerignore) and never bake secrets into images. In the stack above only Caddy publishes ports; never publish the database port.
- Firewall default-deny with only ports 80 and 443 public; SSH by keys only with no root login.
- Pin image versions, run the app container as a non-root user, and keep images and the operating system patched.
- Add security headers in Caddy, enforce HTTPS, and put Cloudflare in front where practical.
- Encrypt backups, copy them off the server, and test a restore before go-live.

6.3 What the infrastructure costs you (approximate, October 2026)

Converted at about KES 130 per USD. These are your costs, not client prices. VPS prices have been volatile in 2026: Hetzner raised prices twice and its cheapest tier showed as unavailable in September 2026, with the regular 4 GB plan reported around EUR 20 per month excluding VAT. Compare several providers (for example netcup, IONOS, DigitalOcean, Contabo, local Kenyan hosts) on the day you quote.

Item	Approximate cost	Notes
Domain .co.ke	KES 1,000 - 2,500 per year	Promotions from KES 399 to 999 in year one; renewals KES 1,200 - 2,500. Add 16 percent VAT
Domain .com	KES 1,200 - 2,600 per year	Check renewal price, not just first-year price
Shared hosting (Kenyan hosts)	KES 3,000 - 10,000 per year	Estimate. Suitable for brochure sites and WordPress only
Entry VPS (2 vCPU, 4 GB RAM)	KES 650 - 3,500 per month	Runs several small Docker apps or one small POS. Price depends heavily on provider
Mid VPS (4 vCPU, 8 GB RAM)	KES 2,000 - 5,500 per month	Larger systems, AI workloads, staging plus production
Managed database (optional)	From about KES 2,000 per month	Or run PostgreSQL in Docker on the same VPS at no extra cost
Backups (snapshots, object storage)	KES 300 - 1,000 per month	Usually around 20 percent of server price; test restores monthly
Docker Engine, Compose, Git, CI basics	Free	Free registries and CI tiers are enough to start
Security scanners (gitleaks, Bandit, pip-audit, Trivy, OWASP ZAP)	Free	Open-source tools used in the Security Baseline testing plan
SSL certificates	Free	Let's Encrypt or Caddy automatic certificates
CDN, DNS and basic firewall	Free tier available	Cloudflare free plan
Uptime and error monitoring	Free tier available	UptimeRobot and Sentry free plans for small projects
Business email	KES 0 - 1,000 per user per month	Free and paid options exist; pick one and standardise
SMS (bulk)	About KES 0.8 - 1.5 per SMS	Estimate. Confirm with your provider; pass through to client

Item	Approximate cost	Notes
M-Pesa Daraja API	No API fee	Client needs a Paybill or Till; Safaricom transaction charges apply; go-live approval takes time
Google Play developer account	USD 25 one-time	In the client's name
Apple Developer Program	USD 99 per year	In the client's name

6.4 Hosting and maintenance packages to sell

Package	Best for	Your cost per month	Charge client per month
Starter Hosting	Brochure and small business websites	KES 300 - 800	KES 500 - 1,000 (or KES 6,000 - 10,000 per year including domain)
Business App Hosting	Small apps and shop POS on a shared VPS (Docker)	KES 500 - 1,200	KES 2,500 - 5,000
Dedicated App VPS	One client, 2 vCPU and 4 GB, Docker, PostgreSQL, backups, monitoring	KES 2,000 - 4,500	KES 6,000 - 12,000
High-Availability / Large	4 vCPU and 8 GB, separate database, staging environment	KES 6,000 - 12,000	KES 18,000 - 35,000

Maintenance plan	Includes	Charge per month
Basic	Backups, security and package updates, uptime monitoring, up to 2 hours of fixes. Office hours only	KES 5,000
Standard	Basic plus 4 to 6 hours of changes, 24-hour response, monthly report, quarterly access review and header and TLS recheck. Office hours only	KES 10,000 - 15,000
Premium	10 or more hours, 4-hour response on critical issues, quarterly security review, restore test	KES 25,000 and above
POS Care	For shops, restaurants and any business that cannot trade when the system is down: Standard plus trading-hours cover seven days a week, 2-hour critical response in trading hours, about 8 included hours, quarterly restore test	KES 15,000 - 22,000

Basic and Standard respond in office hours only and are not suitable for businesses that lose sales when the system is down. Offer POS Care in every POS proposal.

6.5 Example yearly running costs (your cost)

- Brochure website: domain about KES 1,500 plus shared hosting about KES 5,000 gives roughly KES 6,500 per year.
- Small shop POS on a shared VPS: about KES 6,000 to 14,400 for server share, KES 2,000 backups and KES 1,500 domain, so roughly KES 10,000 to 18,000 per year.
- Dedicated app VPS: KES 24,000 to 54,000 for the server, plus backups and domain, so roughly KES 28,000 to 60,000 per year. Charged at KES 72,000 to 144,000, the hosting margin pays for your monitoring and support time.

7. AI-Assisted Delivery Workflow

Stage	Tool	Output	Human gate
1. Discovery	You and the client	Completed SRB sections 1-4 and 15-17, risk level chosen, estimate with VAT-inclusive totals	Client signs scope and the Development Agreement before any deposit or work
2. Specification	GPT	Page specs, workflows, database entities drafted from the SRB; threat model drafted with the Threat Model Prompt	You review for gaps, business rules and security
3. Design	GPT (page designs)	Mockups for every page in the inventory	Client approves designs
4. Build	Claude (code generation)	One module at a time: models, routes, templates, tests, built with the Security Prompt Block	You read the code and run it, and read all authentication, money and permission code line by line
5. Review	You, plus AI second review	Security Review Prompt in a separate AI session; scans (gitleaks, Bandit, pip-audit, Trivy); authorisation tests; money logic; edge cases; device testing	Release checklist passed; no Critical or High finding open

Stage	Tool	Output	Human gate
6. Staging and UAT	Client	Real users test on a staging link; security tests on staging (ZAP, TLS, headers, ports, exposed files, restore test)	Written acceptance (7 business days of testing plus 3 to retest)
7. Deploy and handover	You	Production on Docker, backups on, monitoring and alerts live, docs, training and the evidence pack delivered	Security release gate signed; final payment and sign-off

Review checklist before every release

- Security: authentication, authorisation on every route and on record ownership, SQL injection, XSS, CSRF, file uploads, exposed keys or debug mode left on, secrets in Git history, open ports. Run the Security release gate (Security Baseline section 7).
- Money and stock logic tested by hand against the worked examples in SRB section 16 (totals, tax, rounding, refunds).
- Edge cases: empty data, wrong input, double clicks, slow or dropped network, two users editing the same record, replayed payment callbacks.
- Real-device and multi-browser testing; backup and restore tested once.
- You remain accountable for what ships. Slow down most on payments, user data and permissions.

Prompt templates

Design prompt (GPT): You are a UI designer. Using the page spec below and brand guide (colours, fonts, logo), design the [page name] for [user role] on mobile and desktop. Include empty, loading and error states. List components and spacing.

Build prompt (Claude): Stack: Flask, SQLAlchemy, PostgreSQL, vanilla HTML/CSS/JS. Build only the [module] module from the SRB sections pasted below. Include models, routes, templates, validation, role checks and tests. Return full file contents and list any new files with where they go. Then apply the Security Prompt Block below.

> **Security Prompt Block (add to every build prompt; the full version is in the Security Baseline, section 9.1):**
>
> 1. Hash passwords with argon2id or bcrypt; rate-limit login, reset and OTP; sessions in HttpOnly, Secure, SameSite cookies; never store tokens in localStorage.
>
> 2. Deny by default: every route checks authentication, role AND ownership of the record on the server. Return a permission map. Never rely on hidden buttons.
>
> 3. Validate every input on the server; parameterised queries only; escape output; CSRF protection; allow-list updatable fields.
>
> 4. Secrets only from environment variables; provide .env.example and a .gitignore that excludes .env. Debug off in production; generic errors; no secrets or personal data in logs.
>
> 5. Compute prices and totals on the server; verify webhooks; process each transaction once; confirm payment with the provider.
>
> 6. Use only well-known maintained packages and never invent package names. Include negative tests (not logged in, wrong role, another user's record). List any "Security gaps" at the end.

Security review prompt (second AI session): You are a senior application security engineer doing an adversarial review. Review the code below against the Apex Security Baseline. For each finding give the control ID, severity, file and line, a step-by-step exploit, the fix as code and a test that would catch it. End with a table sorted by severity and a go or no-go recommendation.

Always paste the relevant SRB sections and approved designs into the prompt, and build one module per prompt. Never paste secrets, production data or client personal data into AI tools.

8. Compliance and Legal (Kenya)

Confirm each item with a lawyer or the relevant authority before relying on it. This section is a checklist of topics, not legal advice.

- **Data Protection Act, 2019:** you will process clients' customer data. Check whether Apex must register with the Office of the Data Protection Commissioner, and sign a data processing agreement with each client that handles personal data.
- **Breach response:** every project has an incident response plan. The client, as data controller, must notify the Commissioner and affected people within the legal deadline (understood to be 72 hours for the Commissioner; confirm with an advocate).
- **Data outside Kenya:** store personal data outside Kenya only on the client's written instruction, and confirm the conditions with an advocate.

- **KRA eTIMS:** POS and invoicing systems for VAT-registered businesses may need to integrate with KRA's electronic tax invoice system. Confirm current requirements for each client.
- **M-Pesa:** the client must own the Paybill or Till and complete Safaricom's go-live process. Never hold client funds in your own account.
- **Contracts:** every project needs a signed agreement, signed before the deposit is taken, covering scope, price, payment schedule, intellectual property, warranty period, support terms, security acceptance criteria and liability limits.
- **Company set-up:** register Apex Solutions as a business, obtain a KRA PIN, open a business bank account, and keep invoices and tax filings current.
- **Open-source and AI-generated code:** record licences of libraries used, never paste client confidential data or secrets into AI tools, and check the AI provider's data policy before sending any client data to it.
- **Security claims:** never promise a client that an application is "unhackable" or "100 percent secure". Promise the verified baseline, the evidence pack and the maintenance plan.
- Privacy policy and terms of service pages are required on every client site or app that collects data.

9. Standard Terms (starting template)

Item	Suggested default
Payment	50 percent on signing the Development Agreement, 30 percent on staging approval, 20 percent on go-live. All amounts exclude 16 percent VAT
Start of work	Work starts only after the agreement is signed and the deposit is received. Any paid discovery fee is credited against the deposit
Quote validity	30 days
Revisions	Two rounds of design revisions and one round of code revisions included; further changes are billed via change request
Third-party access	M-Pesa, KRA eTIMS, SMS, gateway and hosting access confirmed in week one. Late access moves the dates and may move go-live
Acceptance testing	7 business days of testing plus 3 business days to retest, with a buffer before go-live. Deemed acceptance if the client goes live or does not respond
Hardware	Supplied, installed and maintained by the client, listed in the blueprint, and outside the warranty
Peak periods	The client names peak trading periods. No go-live or non-urgent changes inside them
Warranty	30 to 60 days of free bug fixes for defects against the signed acceptance criteria
Security	The Apex Security Baseline controls for the project's risk level pass with evidence, and no Critical or High finding is open at go-live. No guarantee of absolute security
Ownership	Client owns the delivered work after final payment; Apex keeps rights to reusable components, templates and tools
Client responsibilities	Supply content, logos and accounts on time; delays move the schedule and may add cost. Keep MFA on their accounts, remove leavers promptly, never share passwords
Hosting and domains	Domain and accounts registered in the client's name; Apex holds admin access while a hosting or maintenance plan is active
Late payment	After 14 days past due a written final notice is sent; services may be suspended 7 days after that notice. For trading systems the client is also warned by phone or WhatsApp. Data is deleted only after 60 days overdue and 14 days' written notice with a chance to export it
Support	Hours, response times and escalation defined by the maintenance plan (Basic, Standard, Premium or POS Care)

10. 90-Day Launch Roadmap

Period	Actions
Days 1-14	Register the business, KRA PIN, business bank account and M-Pesa Till; buy the domain and set up business email; finalise logo and brand colours
Days 15-30	Turn this guide into a reusable SRB template, three packages per Tier 1 service, a contract template and a proposal template. Adopt the Apex Security Baseline: a CI template with gitleaks, Bandit and pip-audit, a hardened Docker template and the authorisation test matrix

Period	Actions
Days 31-60	Build the company website and two or three case studies from existing projects; take two discounted pilot clients in exchange for testimonials. Run the Security Baseline on both and keep the evidence packs
Days 61-90	Launch hosting and maintenance plans (including POS Care); outreach to one niche (for example shops, restaurants or schools); publish the Finance Intel offering as a sample report; line up a certified penetration-testing partner for Level 3 work

11. Universal Pre-Launch Checklist

Area	Check
Business	[ ] Clear purpose [ ] Revenue model [ ] Target users [ ] Agreement signed before the deposit [ ] Signed scope and acceptance criteria [ ] Third-party credentials confirmed in week one
Design	[ ] Mobile responsive [ ] Consistent UI [ ] Accessibility considered [ ] Client-approved mockups
Security	[ ] Security release gate passed [ ] Authentication [ ] Authorisation on every route and record [ ] Audit logs [ ] SSL and security headers [ ] Secrets out of code and Git history [ ] Debug off [ ] MFA on all admin accounts [ ] No Critical or High findings open [ ] Evidence pack and sign-off done
Data	[ ] Backups running [ ] Backups encrypted and off the server [ ] Restore tested [ ] Validation [ ] Data integrity checks
Performance	[ ] Load tested [ ] Optimised queries [ ] Caching where needed [ ] Targets from SRB section 11 met
Operations	[ ] Monitoring and alerts [ ] Error tracking [ ] Documentation [ ] Rollback plan [ ] Incident response plan and contacts [ ] Handover and training done
Compliance	[ ] Privacy policy [ ] Terms of service [ ] Data retention policy [ ] Tax-system and payment requirements confirmed [ ] Data location and processing agreement confirmed

Prices, provider rates and regulatory points were checked in October 2026 and will change. Review this document every quarter.